HONEY95: THREE PLACES TO STOP IT

Social engineering range. Each attack beat a standard piece of advice.

THE ATTACK	1 · HUMAN TELL	2 · CONTROL	3 · SOC SIGNAL
Login window that isn't one AiTM, browser-in-the-browser **Advice:** use MFA. **Result:** it was passed along, live.	Drag the sign-in window to the edge of the page. A fake one stops there; a real window can leave the page and has its own taskbar entry.	Passkeys or FIDO2 keys, bound to the real domain, with weaker fallbacks turned off. Compliant-device checks.	MFA passed from a hosting-provider IP the user never uses, then session use from a different IP or ASN within minutes.
Device-code sign-in Token theft on the real Microsoft page **Advice:** check the URL. **Result:** it was the real one.	Only type a code you started, on a screen you opened. A code handed to you by a web page belongs to the attacker.	Block the device-code flow in Conditional Access except where needed. Require compliant devices.	A sign-in logged with protocol deviceCode, then a new device registration or token use from an unfamiliar location.
"Verify you are human" ClickFix **Advice:** don't download anything. **Result:** you ran it yourself.	A website never needs Win+R. Read anything it gave you in Notepad before you run it.	Block Win+R and restrict PowerShell for standard users. AppLocker or WDAC for scripts.	explorer.exe or a browser starting powershell.exe with hidden-window, bypass or download-and-run arguments.
Look-alike portal Domain confusion on free hosting **Advice:** check the padlock. **Result:** it was real; so was the scam.	Read the domain just before the first single slash. Everything left of it is decoration. Open portals from your bookmark.	Block or isolate sign-in pages on free-hosting platforms. Hold first-seen domains. Origin-bound password managers.	A proxy or DNS hit for a brand keyword inside a free-hosting or first-seen hostname.
Trusted share, wrong file Script behind a real Zoom link **Advice:** verify the sender. **Result:** it really was Zoom.	Show file extensions. A contract is never a .js, .vbs or .hta file.	Open script file types in Notepad by default. Attack surface reduction rules. Mark external shares.	wscript.exe or cscript.exe launched from Downloads, then an outbound connection to an unfamiliar host.
Poisoned package Supply chain, install hook **Advice:** trust popular packages. **Result:** nine days old, three versions.	Check publisher, age and users. A name from a social post is not provenance. Run npm view before you install.	Install with --ignore-scripts. Internal allow-list. Short-lived, scoped publish tokens.	An install process reading ~/.ssh, .env or cloud credentials, then connecting somewhere that is not the registry.

Pick one of each for your environment: a habit people can use, a control you can switch on, a signal you can alert on.

Simulation. Every domain, log and number in the demo is invented. Guidance is indicative: check it against your vendor's documentation.